

EMILIA for Audit & Assurance

A testable control for agentic AI: pre-execution human authorization you can re-perform from raw evidence, without trusting the operator or the AI vendor.

01 THE AUDIT GAP

AI agents now execute inside financially-relevant processes — releasing payments, changing vendor master records, posting adjustments, deploying to production. When an engagement asks *who authorized this action*, the record most organizations can produce is the AI vendor's own activity log. That is a record produced by the party whose product did the harm: it is **testimony, not evidence**. It cannot be recomputed by anyone else's code, and its integrity rests entirely on the operator being both honest and uncompromised.

Post-hoc logs also arrive after the money has moved. A control an auditor can test needs to bind a named human to the exact action *before* execution, and the resulting record needs to verify independently of the system that produced it.

02 THE CONTROL, IN ONE SENTENCE

A named human's device-bound signature over the exact action, captured before execution, verifiable offline by anyone's code.

Enforced by **EMILIA Gate**, a deny-by-default policy-enforcement point: a guarded action runs only with a receipt that is **valid** (Ed25519 over canonical JSON, pinned issuer), **in-scope** (bound to the exact action fields), **sufficiently assured** (cryptographically verified tier — WebAuthn device signoff or M-of-N quorum, never a self-asserted field), **fresh**, and **unused** (one-time consumption). Every decision, allow or deny, is appended to a hash-chained, tamper-evident evidence log.

03 THE EVIDENCE STACK

Six artifacts under the **Admissibility Invariant Registry** — EMILIA's formal statement of *when* evidence is admissible for reliance: signed is not trusted, verified is not accepted, accepted requires pinned policy. Each artifact is computed from the evidence log or the code itself, each deterministic, each carrying its own stated boundary.

ARTIFACT	WHAT THE AUDITOR GETS
Audit workpaper EP-GATE-AUDIT-WORKPAPER-v1	A period workpaper computed purely from the evidence log — decisions, verified tiers, refusals by reason, coverage — deterministic: same log and options in, identical output.
Re-performance kit EP-GATE-REPERFORMANCE-v1	Everything needed to recompute the claims from raw evidence — signatures, hash chain, credited tiers — in the auditor's own environment, trusting nothing asserted.
SOC 2 control mapping EP-GATE-SOC2-MAPPING-v1	Gate mechanisms mapped to the 2017 Trust Services Criteria; every row carries an honest-boundary column stating what the mechanism does <i>not</i> cover.
Control catalog EP-GATE-CONTROL-CATALOG-v1	Each mechanism restated as an auditor-testable control — objective, mechanism, test procedure — phrased for direct inclusion in an existing control matrix.
Art. 14 evidence pack EP-GATE-ART14-PACK-v1	EU AI Act human-oversight evidence: who authorized what at which verified tier, which refusals fired on which predicate, and the coverage ratio of guarded decisions. The renderer refuses a pack whose honesty notice was altered or removed.
Underwriter attestation EP-GATE-UNDERWRITER-ATTESTATION-v1	Evidence that a deny-by-default authorization control was in force and operating over a policy period; entries that cannot be verified are excluded and surfaced as integrity warnings, never counted.

04 RE-PERFORMANCE — TRUST NOTHING, RECOMPUTE EVERYTHING

The stack is built for **re-performance, not inspection**. The auditor's own code recomputes every claim from the raw artifacts: each Ed25519 signature against pinned issuer keys, the hash chain over canonical JSON, the credited assurance tier from per-signer proofs. Nothing the operator asserts is taken on faith. One command replays a full agentic action trail and re-verifies it end to end:

```
$ node examples/audit/agentic-audit-trail-demo.mjs
```

Runs offline against the repository's reference implementation. Any altered or removed record breaks the chain and the verification reports exactly where.

05 WHAT SETS THE CONTROL APART

/ The cryptographic two-person rule

For hard actions, the required tier is *quorum*: M-of-N **distinct humans** with **distinct keys**, threshold met, each signer's assertion bound to the exact action and time window — and each verified independently. "Two people approved this" stops being a screenshot of an approval UI and becomes an artifact the audit can recompute.

/ Break-glass as evidence, never a bypass

There is no "disable the gate" switch. An emergency override is itself a signed M-of-N grant — scoped to listed action types, time-bounded, attributed (reason and incident reference are required), single-use, and appended to the same evidence chain. The exception path produces *stronger* evidence, not a gap.

Module contract: NO EVIDENCE ENTRY, NO OVERRIDE.

06 ENGAGEMENT MODEL

- 1 **Working session.** We walk your audit or assurance team through the evidence stack against one real action flow from your environment — including the re-performance demo above, run on your side.
- 2 **Design-partner pilot.** One consequential action family routed through the Gate, in observe or enforce mode. Deliverables are the artifacts in section 03, computed over your own evidence log — not a slide deck.

STATUS & BOUNDARIES

- **Open standard, individual drafts.** EMILIA Protocol is an open, Apache-2.0 specification. Its Internet-Drafts are active on the IETF's individual stream: drafts by their authors, not IETF-endorsed and not adopted standards.
- **Reference verifiers.** JavaScript, Python, and Go same-team ports agree across 21 suites and 340 vectors. This is cross-language consistency evidence, not three independent implementations.
- **External implementation, precise boundary.** CI rebuilds an externally authored Rust verifier from a pinned public commit and tree. It passes the pinned 16-suite/164-vector clean-room bundle and 359 hostile cases. The construction statement is implementer-signed and predates the current source pin, so strict independently attested clean-room acceptance remains zero.
- **What verification proves.** Signature validity, action binding, tier crediting, and log integrity — not the business correctness of an authorized action. Principal identities are as pinned by the deployer, not independently verified.
- **Not an attestation.** EMILIA Protocol is not an auditor. This brief and the artifacts it describes exist to **support** an audit; nothing here is an attestation, examination, or opinion, and none of these documents makes any system "compliant out of the box."